

HARDENED CLOUD ARCHITECTURES

*Secure Serverless Blueprints & Automated Incident Response
for Fintech Environments*



Zero Trust Architecture

Architected By: Shashank Mudgal

Subject: Architectural Défense: Eliminating Critical Attack Vectors in High-

Availability Cloud Infrastructure

1. Executive Summary

This architecture demonstrates a security-first, highly available AWS deployment designed for modern web applications. It integrates layered defence mechanisms, scalable infrastructure, and automated threat detection and response.

Key highlights:

- Defence-in-depth security model
- IAM Roles with STS for temporary access control
- Multi-AZ high availability design
- Centralized logging and monitoring
- Automated incident response using EventBridge and Lambda

Disclaimer

This is a demo/reference architecture designed to showcase secure AWS design patterns, high availability strategies, and automated threat response mechanisms.

It is not intended to represent a fully production-ready deployment without further customization, cost optimization, and environment-specific tuning.

2. Architecture Overview

The architecture follows a layered approach, ensuring that security and availability are enforced at every stage of the request lifecycle.

High-Level Flow

- User sends request
- Request resolved via Route 53
- Traffic routed through CloudFront (CDN)
- Traffic filtered by AWS WAF / Shield
- Request forwarded to API Gateway / Load Balancer
- Authentication & authorization enforced
- Request enters private VPC
- Processed by compute services (EC2 / Lambda)
- Data retrieved from storage layer (RDS / DynamoDB / S3)
- Logs and events sent to monitoring and response systems

3. Architecture Layers

3.1 Edge & Entry Layer

Services Used:

- Route 53
- CloudFront

Purpose:

- DNS resolution
- Content delivery optimization
- Entry point for all traffic

Security Measures:

- HTTPS enforcement
- TLS termination at edge
- Geo-restrictions
- Reduced latency and attack surface

3.2 Prevention Layer

Services Used:

- AWS WAF
- AWS Shield

Purpose:

- Protect against common web attacks before reaching backend

Security Controls:

- SQL Injection protection
- XSS filtering
- Rate limiting
- IP reputation filtering

Important Note:

WAF rules are dynamically updated by Lambda during incident response (not directly receiving events).

3.3 Authentication & Authorization Layer

Services Used:

- IAM Roles
- AWS STS (Security Token Service)

Purpose:

- Secure access control across services

Security Measures:

- Temporary credentials via STS
- Role-based access control (RBAC)
- Least privilege policies
- No hardcoded credentials

3.4 Network Layer

Services Used:

- Amazon VPC
- Public & Private Subnets
- Internet Gateway
- NAT Gateway

Purpose:

- Network isolation and segmentation

Security Measures:

- Security Groups (stateful firewall)
- Network ACLs (stateless filtering)
- Private subnet isolation for backend resources

3.5 Compute Layer

Services Used:

- EC2 (Auto Scaling)
- AWS Lambda

Purpose:

- Execute application logic

Availability Measures:

- Multi-AZ Auto Scaling
- Stateless compute design

Security Measures:

- IAM roles attached to instances
- No static credentials
- Controlled inbound/outbound access

3.6 Storage Layer

Services Used:

- Amazon RDS (Multi-AZ)
- DynamoDB
- Amazon S3

Purpose:

- Data persistence and storage

Availability Measures:

- Multi-AZ failover (RDS)
- Highly available NoSQL (DynamoDB)

Security Measures:

- Encryption at rest (KMS)
- Encryption in transit (TLS)
- S3 Block Public Access
- Fine-grained IAM policies

3.7 Encryption & Secrets Management

Services Used:

- AWS KMS
- AWS Secrets Manager

Purpose:

- Secure storage of secrets and encryption keys

Security Measures:

- Automatic key rotation
- Access control via IAM
- Secure secret retrieval at runtime

3.8 Detection & Response Layer

Services Used:

- CloudWatch
- CloudTrail
- AWS Config
- EventBridge
- AWS Lambda

Purpose:

- Monitor, detect, and respond to threats

4. Logging Strategy

Log Sources:

- CloudTrail (API activity)
- CloudWatch Logs (application + infra)

Storage:

- Centralized S3 bucket

Pipeline:

- Logs generated by services
- Forwarded to CloudWatch / CloudTrail
- Stored in S3 for long-term retention

Security Enhancements:

- Bucket access restrictions
- Log integrity protection
- Lifecycle policies for cost optimization

5. Automated Incident Response

Trigger Mechanism:

- Suspicious activity detected via logs

Flow:

1. EventBridge rule detects anomaly
2. Lambda function is triggered
3. Lambda performs:
 - Updates WAF rules (e.g., block malicious IP)
 - Sends alert (SNS / Email / Slack)
 - Logs incident details in S3

6. Security Architecture

Core Principles

- Least Privilege Access
- Defence in Depth
- Zero Trust Model

Key Controls

- IAM Roles + STS (temporary credentials)
- WAF + Shield (edge protection)
- Encryption using KMS
- Network isolation using VPC
- Continuous monitoring & logging

7. Availability & Resilience

- Multi-AZ deployment
- Auto Scaling for compute
- Managed database failover (RDS)
- Stateless application design
- Highly available storage systems

Outcome:

Elimination of single points of failure.

8. Use Cases

1. SaaS Platforms

- Multi-tenant secure architecture
- Scalable backend services

2. Fintech Applications

- Strong access control
- Full audit logging (CloudTrail)

3. E-commerce Systems

- High availability under heavy load
- DDoS protection via WAF & Shield

4. API-Driven Microservices

- Secure API Gateway integration
- Event-driven workflows

5. Security-Critical Applications

- Real-time threat detection
- Automated mitigation

9. Key Highlights

- End-to-end secure architecture
- Uses temporary credentials (STS) instead of static keys
- Fully integrated automated threat response system
- Covers all layers:
 - Edge
 - Identity
 - Network
 - Compute
 - Storage
 - Monitoring

10. Future Enhancements (Optional but Smart to Add)

- Infrastructure as Code (Terraform / CloudFormation)
- CI/CD pipeline integration
- Security scanning (SAST, DAST, SCA)
- Advanced threat detection (GuardDuty, Security Hub)
- Zero Trust Network Architecture (ZTNA)